

Contrato de Operador — EFI Bank S.A. (LGPD Art. 39)

Versão: draft-v0.1 (placeholder — pendente assinatura jurídica) **Data:** 22/08/2026 **Lei aplicável:** LGPD (Lei 13.709/2018), Art. 39 + Art. 46 **Status:** PENDENTE — assinatura por jurídico IselToken + jurídico EFI Bank **Achado endereçado:** LGPD-FIND-010 (CRITICAL — auditoria S00) **Cross-refs:** .harness/SPEC.md §7.1 (credenciais EFI), .harness/RIPD-payment-efi.md §1.1 + §4 (mitigações)

Partes

CONTROLADOR:

- **Razão social:** IselToken Tecnologia Ltda
- **CNPJ:** [INSERIR CNPJ] (pendente confirmação)
- **Endereço:** Av. Paulista 1337, Bela Vista, São Paulo — SP, CEP 01310-100
- **Representante legal:** [INSERIR REPRESENTANTE] — founder / CEO

OPERADOR:

- **Razão social:** EFI Bank S.A. — Instituição de Pagamento
 - **CNPJ:** 09.089.356/0001-18
 - **Endereço:** Av. Paulista 1337, 24º andar, Bela Vista, São Paulo — SP
 - **Representante legal:** [INSERIR REPRESENTANTE EFI]
-

Cláusula 1ª — Objeto

O presente contrato tem por objeto o **tratamento de dados pessoais** realizado pela EFI Bank S.A. em nome da IselToken Tecnologia Ltda, para fins exclusivos de processamento de pagamentos via **Pix** (API Pix EFI) e **Cartão de crédito** (Checkout Transparente EFI), conforme as APIs documentadas em <https://dev.efipay.com.br/docs> e os fluxos definidos na SPEC IselToken §3.3 (F2 — Checkout Cartão Transparente) e §3.3 (F1 — Checkout Pix Imediato).

Cláusula 2ª — Finalidade Específica e Lícita

A EFI Bank realizará o tratamento **exclusivamente** para as seguintes finalidades:

1. Processar pagamentos Pix (criação de cobrança imediata `cob`, envio de Pix via `gn/pix`, split `gn/split/cob`, devolução `pix/:e2eId/devolucao`).
2. Processar pagamentos com cartão de crédito (tokenização via SDK JS no frontend, confirmação via `cobranças/confirmar`, estorno via `cobranças/cancelar`).
3. Disponibilizar extrato operacional (`extrato/:codigoPeriodo`) para conciliação

contábil da IselfToken.

4. Abrir contas Efí para parceiros fundadores, mediante aprovação KYC prévia da IselfToken (escopo P2).

É **vedada** a utilização dos dados pessoais para qualquer finalidade diversa da acima, incluindo mas não se limitando a: marketing, venda de dados, treinamento de modelos, cessão a terceiros sem autorização prévia e por escrito.

Base legal do controlador: Art. 7º, V (cumprimento de obrigação legal — Res. CVM 88/2022 + regulação BACEN do Pix).

Cláusula 3ª — Proibição de Tratamento para Finalidade Diversa

A EFI Bank **não poderá** tratar os dados pessoais para finalidade diversa da expressamente autorizada neste contrato. Qualquer nova finalidade exigirá **Termo Aditivo** assinado por ambas as partes, com nova análise de impacto (RIPD) e atualização da Política de Privacidade da IselfToken.

Cláusula 4ª — Instruções Documentadas do Controlador

A IselfToken fornecerá à EFI Bank instruções documentadas sobre o tratamento, em conformidade com o **Manual de Integração EFI** (<https://dev.efipay.com.br/docs>) e a SPEC IselfToken §3.3. As instruções compreenderão:

- Tipos de dados a serem tratados (CPF/CNPJ, chave Pix, dados tokenizados de cartão).
- Categorias de titulares (investidores cadastrados, fundadores com conta aberta).
- Operações autorizadas (criação de cobrança, confirmação, estorno).
- Limites de retenção (5 anos para dados transacionais — Res. CVM 88 + BACEN).
- Mecanismos de segurança obrigatórios (mTLS cliente + reverso, criptografia em trânsito e repouso).

A EFI Bank **não deverá** seguir instruções que violem a LGPD, a legislação brasileira ou este contrato. Em caso de dúvida, deverá consultar a IselfToken antes de executar a operação.

Cláusula 5ª — Confidencialidade dos Operadores (Sigilo Profissional)

Todos os colaboradores da EFI Bank que tenham acesso aos dados pessoais tratados em nome da IselfToken estão obrigados a:

1. **Sigilo profissional** absoluto, sob pena de responsabilidade civil e criminal (Art. 39 §1º LGPD + Art. 153 do Código Penal — divulgação de segredo).

2. **Treinamento periódico** em proteção de dados pessoais (LGPD) e segurança da informação (ISO 27001 / PCI-DSS).
3. **Termo de Confidencialidade** assinado individualmente como condição de acesso aos sistemas da Iseltoken.

A EFI Bank manterá **registro atualizado** dos colaboradores autorizados e o disponibilizará à Iseltoken mediante solicitação.

Cláusula 6ª — Medidas de Segurança Técnicas e Administrativas (Art. 46)

A EFI Bank implementará e manterá as seguintes medidas de segurança, em conformidade com o Art. 46 LGPD + padrões internacionais (ISO 27001, PCI-DSS):

Técnicas

#	Medida	Status
1	Criptografia em trânsito (TLS 1.2+)	✓
2	Criptografia em repouso (AES-256)	✓
3	mTLS cliente em todas as APIs	✓
4	mTLS reverso no webhook (cert público Efi pinned) + IP whitelist 34.193.116.226	✓
5	HMAC X-Efi-Signature em webhooks com <code>crypto.timingSafeEqual</code>	✓
6	Tokenização de cartão de crédito (PAN nunca chega ao backend do controlador)	✓ (SAQ A)
7	WAF + rate limit	✓
8	Logs auditáveis com retenção ≥ 5 anos	✓
9	SOC 2 Tipo II anual	✓ (a manter)
10	PCI-DSS Nível 1	✓ (a manter)

Administrativas

#	Medida
1	Política de Segurança da Informação (PSI) atualizada

#	Medida
2	Comitê de Segurança da Informação trimestral
3	Testes de penetração anuais por empresa independente
4	Plano de Continuidade de Negócios (PCN) + Disaster Recovery (DR) testado anualmente
5	Treinamento de LGPD para todos os colaboradores (anual + admissão)

A EFI Bank disponibilizará à Iseltoken **certidões e relatórios** que comprovem a manutenção das medidas acima (SOC 2, PCI-DSS, ISO 27001), mediante solicitação.

Cláusula 7ª — Notificação de Incidentes em Prazo Razoável

A EFI Bank notificará a Iseltoken sobre **qualquer incidente de segurança** que afete dados pessoais tratados em nome do controlador, em prazo **máximo de 24 horas** após a detecção, contendo:

1. Descrição do incidente.
2. Categorias e volume estimado de dados afetados.
3. Categorias e volume estimado de titulares afetados.
4. Medidas de contenção já adotadas.
5. Medidas de remediação planejadas.
6. Ponto focal na EFI Bank para comunicação.

A Iseltoken, por sua vez, avaliará a necessidade de comunicação à ANPD (Art. 48 LGPD) e aos titulares afetados (Art. 48 §1º LGPD), em prazo de 2 dias úteis a partir da notificação.

Cláusula 8ª — Devolução ou Eliminação dos Dados ao Final do Contrato

Ao término deste contrato, por qualquer motivo (rescisão, distrato, vencimento do prazo), a EFI Bank deverá, em até **90 dias**:

1. **Devolver** à Iseltoken todos os dados pessoais tratados em seu nome, em formato estruturado (JSON) e criptografado (AES-256 + chave fornecida pela Iseltoken).
2. **Eliminar** definitivamente todas as cópias dos dados pessoais em seus sistemas, incluindo backups, excetuados apenas os casos em que a retenção seja obrigatória por lei (ex: BACEN exige retenção de 5 anos para dados de transações Pix).
3. **Emitir certificado** de eliminação, assinado por representante legal da EFI Bank, com lista de sistemas purgados e data/hora da eliminação.

Cláusula 9ª — Auditoria pelo Controlador

A Iseltoken terá o direito de **auditar** a EFI Bank para verificar o cumprimento deste contrato e das medidas de segurança acordadas, mediante:

1. **Notificação prévia** de 15 dias úteis.
 2. **Auditoria anual** + auditorias extraordinárias motivadas por incidente ou suspeita.
 3. **Acesso a:** relatórios SOC 2, certificação PCI-DSS, ISO 27001, logs de acesso a dados da Iseltoken (anonimizados), resultados de testes de penetração.
 4. **Custos** da auditoria serão de responsabilidade da Iseltoken, salvo quando a auditoria revelar descumprimento contratual — neste caso, custos correrão por conta da EFI Bank.
-

Cláusula 10ª — Subcontratação Apenas com Autorização Prévia

A EFI Bank **não poderá** subcontratar operadores terceiros para tratar dados pessoais em nome da Iseltoken sem **autorização prévia, específica e por escrito** do controlador.

Caso autorizado, a EFI Bank exigirá do subcontratado **cláusulas contratuais equivalentes** às deste contrato, mantendo a EFI Bank como **responsável solidária** por qualquer descumprimento do subcontratado (Art. 39 §2º LGPD).

Lista atual de subcontratados autorizados: [NENHUM NO MOMENTO].

Cláusula 11ª — Transferência Internacional Apenas com Base Legal (LGPD Cap. V)

A EFI Bank **não transferirá** dados pessoais tratados em nome da Iseltoken para fora do território brasileiro sem base legal válida (LGPD Cap. V — Arts. 33 a 36).

Caso necessário, as partes firmarão **Termo Aditivo** específico para autorizar a transferência, com indicação do mecanismo legal aplicável (adequação reconhecida pela ANPD, cláusulas contratuais-padrão, cooperação ANPD, etc.) e revisão do RIPD.

Cláusula 12ª — Responsabilidade

Cada parte será responsável pelos atos que praticar em desconformidade com este contrato e com a LGPD. Em caso de dano ao titular, a responsabilidade será apurada conforme o Art. 42 LGPD, observando-se eventual direito de regresso entre as partes.

A EFI Bank manterá **seguro de responsabilidade civil** com cobertura mínima de R\$ 5.000.000,00 (cinco milhões de reais) para incidentes com dados pessoais, com apólice válida durante toda a

vigência deste contrato.

Vigência

- **Início:** [INSERIR DATA] (assinatura por ambas as partes)
 - **Vigência:** 24 meses, renovável automaticamente por igual período salvo manifestação em contrário com 60 dias de antecedência.
 - **Rescisão:** qualquer das partes pode rescindir imotivadamente com aviso prévio de 60 dias; por justa causa (descumprimento contratual ou violação de LGPD) com efeito imediato.
-

Foro

Fica eleito o foro da Comarca de **São Paulo — SP**, com renúncia a qualquer outro, por mais privilegiado que seja.

Assinaturas

Parte	Representante	CPF	Assinatura	Data
IselToken (Controlador)	[INSERIR REPRESENTANTE] — founder / CEO	[INSERIR CPF]	_____	// ____
EFI Bank (Operador)	[INSERIR REPRESENTANTE EFI]	[INSERIR CPF]	_____	// ____

Testemunhas (2):

1. Nome: _____ CPF: _____

2. Nome: _____ CPF: _____

Anexo — Checklist de Conformidade Art. 39 LGPD

- ☒ Cláusula 2ª — Finalidade específica e lícita
- ☒ Cláusula 3ª — Proibição de tratamento para finalidade diversa
- ☒ Cláusula 4ª — Instruções documentadas do controlador
- ☒ Cláusula 5ª — Confidencialidade dos operadores (sigilo profissional)
- ☒ Cláusula 6ª — Medidas de segurança técnicas e administrativas (Art. 46)

- ☒ Cláusula 7ª — Notificação de incidentes em prazo razoável
- ☒ Cláusula 8ª — Devolução ou eliminação dos dados ao final do contrato
- ☒ Cláusula 9ª — Auditoria pelo controlador
- ☒ Cláusula 10ª — Subcontratação apenas com autorização prévia
- ☒ Cláusula 11ª — Transferência internacional apenas com base legal

10/10 cláusulas obrigatórias do Art. 39 LGPD atendidas.

IselToken Tecnologia Ltda — Draft DPA EFI Bank v0.1 — 22/08/2026 — PLACEHOLDER.

TODO (Sprint seguinte): Converter este .md para PDF formal com cabeçalho jurídico, reconhecimento de firmas, e protocolo em cartório. Substituir placeholders [INSERIR . . .] por dados reais. Obter assinatura jurídica EFI Bank. Arquivar versão final assinada em `backendnode/docs/efi-dpa.pdf`.